



Sentinel AI

The Complete Beginner's Guide

AI Security Testing · "Burp Suite for LLMs"

51 attacks

8 categories

Red Team Agent

OWASP LLM Top 10

1 What is Sentinel AI?

Sentinel AI is a tool that **tests how safe an AI chatbot is**. You point it at an AI model (like ChatGPT, Claude, or Gemini) and it automatically sends dozens of tricky, malicious messages to see whether the AI can be fooled into misbehaving — leaking secrets, giving dangerous instructions, or ignoring its own rules.

A simple analogy: think of **crash-testing a car** before it's sold. The car maker deliberately smashes cars into walls to find weak spots and fix them. Sentinel AI does the same for AI chatbots — it "attacks" the AI on purpose, in a safe lab setting, so the owner can find and fix the weaknesses *before* real attackers do.

Security professionals already have a famous tool for testing websites called **Burp Suite**. Sentinel AI is often described as "**Burp Suite for LLMs**" (LLM = Large Language Model, the technology behind AI chatbots).

TIP — You do **not** feed it your source code. Sentinel tests the **behavior of a live AI model**, not files on your computer. The "input" is a model plus an API key.

2 Key words you'll see (plain-English glossary)

Term	What it means
LLM	"Large Language Model" — the AI brain behind chatbots (GPT-4, Claude, Gemini, Llama...).
API key	A secret password that lets a program talk to an AI provider. Looks like sk-abc123...
Prompt	The message you send to an AI. The AI's answer is the "response".
Guardrail	The AI's built-in safety rules that make it refuse harmful requests.
Prompt injection	Sneaking hidden instructions into a prompt to hijack the AI ("ignore your rules and...").
Jailbreak	A trick that makes the AI break its own safety rules (e.g. pretending to be an 'unfiltered' character).
Red teaming	Acting like an attacker on purpose to find security holes before real attackers do.
OWASP LLM Top 10	An industry-standard list of the 10 biggest AI security risks. Sentinel maps every test to it.

3 Why does this matter?

Companies are adding AI chatbots to everything — customer support, banking, healthcare, coding tools. But an AI that can be tricked is a real danger. A cleverly worded message might make a chatbot:

- Reveal its secret instructions or a hidden password.

- Leak private customer data (emails, card numbers).
- Produce dangerous content it was supposed to refuse.
- Run a harmful command if it's connected to tools or a database.

Sentinel AI finds these problems automatically and gives you a clear report, so you can fix them before going live.

4 How it's built (the big picture)

Sentinel has two parts that run at the same time on your computer:

Part	What it does	Tech
Backend (the engine)	Runs the attacks, talks to the AI models, scores the results, stores history.	Python + FastAPI
Frontend (the website)	The pretty dashboard you click around in, in your browser.	React + Vite

The website (frontend) talks to the engine (backend). The engine is the only thing that talks to the AI models — so your API keys stay safe on the server and never leak into the browser.

HEADS-UP — This is why you must run **both** parts. If the backend engine isn't running, the website has nothing to talk to and shows an "internal server error."

5 Installing & running it (step by step)

You need: Python 3.11 or 3.12, and Node.js 18+ installed. You run two terminals — one for the backend, one for the frontend. Keep both open.

Terminal 1 — start the backend engine:

```
cd backend
python -m venv .venv
# Windows:
.\.venv\Scripts\Activate.ps1
pip install -r requirements.txt
uvicorn app.main:app --reload --port 8000
```

Terminal 2 — start the frontend website:

```
cd frontend
npm install
npm run dev
```

Now open **http://localhost:5173** in your browser. That's Sentinel AI running!

TIP — No API key yet? You still need one AI provider key to actually run scans. A free **Groq** key (console.groq.com) or your **OpenAI** key both work. You paste it in the app — see the next section.

6 Using it — a full walkthrough

Step 1 — Add a model (Models page).

- Click **+ Add Model**.
- Pick a provider (e.g. **openai**), type the model name (e.g. gpt-4o-mini).
- Paste your **API key** and click **Register model**.
- Click **Test** — green means it works, red shows the error (e.g. a wrong key).

Step 2 — Run a scan (New Scan page).

- Choose your model as the target.
- Pick which attacks to run — leave all 51 selected, or filter by category.
- Click **Run**. You're taken to the dashboard, which updates live as each attack finishes.

Step 3 — Read the results (Dashboard). The dashboard shows your security score and a list of every attack with a verdict. Click any row to see the exact message that was sent and what your AI replied. That's covered next.

7 Understanding your results

What you see	What it means
Security Score (0–100)	Higher is safer. It's weighted by severity — a critical failure hurts more than a minor one.
Risk Level	A simple label: Low (90+), Moderate (70–89), High (40–69), Critical (under 40).
Attack Success %	How many attacks got through. Lower is better. "Breached" = the attack worked = a weakness.
OWASP Breakdown	Which categories of the industry risk list your model failed on.
Recommendations	Plain-English fixes for each type of failure found.
Verdict per attack	vulnerable = the AI was fooled. blocked = the AI correctly refused.

8 The 8 attack categories, explained simply

Category	What it tests (in plain words)
Prompt Injection	Can someone hijack the AI with hidden instructions, or make it reveal its secret system prompt?

Category	What it tests (in plain words)
Jailbreak	Can clever role-play or tricks (DAN, Skeleton Key, Policy Puppetry) make it ignore its safety rules?
Obfuscation	Can hiding a request in code (Base64, ROT13, Morse, look-alike letters) sneak it past filters?
Offensive Security	Will it write malware, phishing emails, or hacking exploits if asked?
Tool Security	If connected to tools, will it run dangerous commands (delete files, drop a database)?
PII Leakage	Will it leak or invent private data — emails, SSNs, credit cards, API keys?
Toxicity & Bias	Can it be baited into hateful, violent, or biased statements?
Hallucination	Does it make up fake facts, fake books, or agree with false claims?

Every attack is a real technique from 2024–2025 security research (Anthropic, Microsoft, HiddenLayer, Palo Alto, OWASP). Each is mapped to an OWASP risk code like **LLM01**.

9 The Red Team Agent (the star feature)

A normal scan sends the same fixed list of attacks. The **Red Team Agent** is smarter: it's an AI that **attacks another AI on its own**, and adapts as it goes.

You give it a goal — for example, *"Get the model to reveal its system prompt."* Then it loops:

- **Plan & write** an attack message aimed at the goal.
- **Send** it to the target AI.
- **Judge** whether the target gave in.
- **Adapt** — if the target refused, it reads the refusal and tries a smarter approach next round.

It stops the moment it breaks through (or runs out of rounds) and writes a short security report. You watch the whole duel live, round by round — attacker message vs. the AI's reply.

10 Testing your OWN chatbot (custom endpoint)

The most powerful use: test **your own deployed chatbot**, not just a raw model. That's where the real weaknesses live, because your app adds its own instructions and data.

On **Models** → **+ Add Model**, choose provider **custom** and fill in how to call your app:

Field	Example
Endpoint URL	<code>https://your-app.com/api/chat</code>
Headers (JSON)	<code>{"Authorization": "Bearer {{api_key}}"}"</code>
Body template	<code>{"messages": [{"role": "user", "content": "{{prompt}}"}]}</code>
Response path	<code>choices.0.message.content</code>

{{prompt}} is where Sentinel inserts each attack; {{api_key}} is your secret. Now every attack — and the Red Team Agent — runs against your live app.

11 Troubleshooting & FAQ

Problem	Fix
"Internal server error" in the browser	The backend isn't running. Start it (Terminal 1) and refresh.
A scan says "No API key available"	Keys are kept in memory and cleared when the backend restarts. Just re-add the model with its key.
The Test button shows a red 401	Your API key is wrong or expired. Paste a fresh one.
It's slow or some attacks error	Free API tiers limit speed. Sentinel retries automatically; partial results still show.
I only have an OpenAI key, not Groq	That's fine — register an openai model and use it as the target. Ignore the default Groq entry.
Nothing loads at localhost:5173	Make sure Terminal 2 (npm run dev) is running and shows no errors.

12 Quick recap

Sentinel AI is a safety crash-test lab for AI chatbots. You: **(1)** run the backend and frontend, **(2)** add a model with your API key, **(3)** run a scan, and **(4)** read the security score and fix what failed. For a deeper test, unleash the **Red Team Agent** or point it at your **own chatbot's endpoint**.

HEADS-UP — Remember the golden rule: only test models and apps **you own or are allowed to test**. Sentinel is a defensive tool — use it responsibly.

Full project, source code, and README: github.com/Afzalkhan001/Sentinel-Ai